

Política de Seguridad de la Información

OpenTrust Demo Services, S.L. · POL-SGSI-001 · Versión 2.1

DATOS DE DEMOSTRACIÓN - ORGANIZACIÓN FICTICIA

Código	POL-SGSI-001
Propietario	Dirección / CISO
Versión	2.1
Fecha de aprobación	15/01/2026
Próxima revisión	15/01/2027
Clasificación	Uso interno - Demo
Controles relacionados	5.2, A.5.1, A.5.2, A.5.36

1. Objeto

Definir los principios, responsabilidades y reglas generales para proteger la confidencialidad, integridad, disponibilidad, autenticidad y trazabilidad de la información de OpenTrust Demo Services, S.L.

2. Alcance

Aplica a las sedes de Madrid y Barcelona, personal remoto, servicios cloud, aplicaciones corporativas, infraestructura de red, proveedores críticos y datos tratados por la organización ficticia.

3. Contexto tecnológico

Plataforma	Uso	Criticidad	Protección principal
Microsoft 365 / Entra ID	Identidad y colaboración	Alta	MFA, Conditional Access, PIM
Azure West Europe	Producción	Alta	NSG, WAF, Key Vault, Sentinel
Azure North Europe	Continuidad	Alta	Réplicas, backups y DR
Cloudflare	DNS, CDN, WAF y Zero Trust	Alta	WAF gestionado, rate limiting
GitHub Enterprise Cloud	Código y CI/CD	Alta	SSO, branch protection, Dependabot

4. Principios

- Gestión de riesgos basada en el impacto sobre servicios, datos, clientes y obligaciones.
- Acceso bajo mínimo privilegio, necesidad de negocio, MFA y revisión periódica.
- Seguridad integrada en proyectos, cambios, compras y ciclo de vida de desarrollo.
- Registro y monitorización de actividades relevantes en Microsoft Sentinel.
- Copias de seguridad protegidas, inmutables y sometidas a pruebas de restauración.
- Gestión de incidentes con preservación de evidencias y lecciones aprendidas.
- Evaluación previa y seguimiento anual de proveedores críticos.

5. Roles y responsabilidades

Rol	Responsabilidad	Evidencia esperada
Dirección	Aprobar política, recursos, objetivos y apetito de riesgo	Actas de revisión y decisiones
CISO	Mantener el SGSI, coordinar riesgos y auditorías	SoA, riesgos, informes, KPIs
IT / Infraestructura	Operar identidades, redes, backups y plataformas	Registros operativos y cambios
SOC	Monitorizar, investigar y responder a incidentes	Casos SIEM, bitácoras y post-mortem
Propietarios de activos	Aprobar accesos, clasificación y tratamientos	Aprobaciones y revisiones

Usuarios	Cumplir políticas y notificar eventos	Aceptación, formación y reportes
----------	---------------------------------------	----------------------------------

6. Objetivos 2026

Objetivo	Meta	Resultado demo	Estado
Cierre de vulnerabilidades críticas	≤ 15 días	83%	Parcial
Recertificación de accesos	100% trimestral	92%	Parcial
Formación anual	≥ 95%	91%	Parcial
Restauraciones correctas	100%	100%	Cumple
Cobertura de logs críticos	≥ 95%	96%	Cumple

7. Excepciones

Toda excepción requiere propietario, justificación, evaluación de riesgo, control compensatorio, aprobación del CISO y fecha de caducidad no superior a 180 días.

8. Cumplimiento y revisión

La política se revisa al menos anualmente y tras incidentes graves, cambios regulatorios o modificaciones significativas de la arquitectura. Los incumplimientos generan acciones correctivas.